

An Artificial Intelligence Approach for Deploying Zero Trust Architecture (ZTA)

Eslam Samy Hosney¹, Islam Tharwat Abdel Halim^{1,2}, Ahmed H. Yousef^{1,3}

¹*School of Information Technology and Computer Science (ITCS), Nile University, Giza, Egypt*

²*Center for Informatics Science, Nile University, Giza, Egypt*

³*Faculty of Engineering, Ain Shams University, Cairo, Egypt*

eslamsamymeg@gmail.com; ihalim@nu.edu.eg; ahassan@nu.edu.eg

Abstract— Cybersecurity is critical in preventing infractions, maintaining digital workplace discipline, and ensuring that laws and regulations are obeyed. Zero Trust Architecture (ZTA), often known as perimeter-less security, is a novel method for designing and implementing secured IT systems. Zero trust's basic notion is "never trust, always verify," which indicates that devices should not be trusted by default. This means that each access from or to any asset must be assessed and follow the standard guidelines of the organization. Maintaining this type of control imposes a high burden on IT security and system administrators to be able to track and validate each control and manually sustain the configuration needed. With the power of Classification Algorithms in Machine Learning, we will explore in this paper an alternative solution to save time and effort and help maintain the same security posture with less human intervention. The proposed approach utilizes the information from available security feeds and statically configured policies to enforce and maintain zero-trust network policies. By analyzing the data, it will be feasible to identify the required policies to be configured and compare them against the traditional compliance rules to auto-configure the policies. This approach aims to enhance the existing security intelligence engines with more sophisticated rules and less time and effort.

Keywords — Cybersecurity, Machine Learning, Zero Trust

I. INTRODUCTION

With digital transformation, the proliferation of disruptive technologies, and the emergence of trends such as telecommuting, the digital boundaries of businesses have disappeared [1]. The disappearance of these limits makes traditional perimeter security solutions inadequate to meet the growing demands for remote access. Especially with the growth of network size, Cisco expects the number of devices connected to IP networks to grow from 18.4 billion in 2018 to 29.3 billion by 2023 [2]. The combination of these developments and the worrying increase in security incidents and data breaches has destroyed the concept of trust as it is viewed as a vulnerability. Thus, zero-trust security has been proposed recently based on the following principle: "never trust, always verify" [3]. Accordingly, zero-trust security requires strict and continuous identity verification to reduce implicit trust zones.

The phrase "zero trust" refers to a group of growing cybersecurity paradigms that are shifting the focus of defenses away from static network perimeters and toward users, resources, and assets. Zero trust presupposes that no implicit trust is put in assets or user accounts purely based on their physical location, network connectivity (i.e., local area network or Internet), or asset ownership (corporate or personal). Zero trust is a response to emerging developments in corporate networks, such as remote users, Bring Your Own Device (BYOD) initiatives and cloud assets located outside the corporate network's perimeter. Zero trust focuses on securing resources (assets, services, processes, and network accounts, for example), not network segments because the location of a resource on the network is no longer the fundamental factor determining its security status. In this context, the US National Institute of Standards and Technology (NIST) recently published a blueprint that explains how to build effective Zero Trust Architectures (ZTA) [4]. However, to date, the use of these solutions is difficult due to a lack of maturity; the deployment is likely to lead to installation or configuration errors, increase the vulnerability of information systems, and give companies a false sense of security.

Besides, with the growing popularity of Artificial Intelligence (AI) technologies, which have advanced to the point where they are now major actors in the realm of cybersecurity [5]. AI offers a wide range of applications in cybersecurity, including recognizing cyber risks, optimizing available antivirus software, and combating cybercrime that incorporates AI skills. This point is critical since many hackers also employ AI to strengthen and improve their cyberattacks [6]. Additionally, 75% of CEOs questioned felt that AI enables a more rapid reaction to security incidents. As a result, cybersecurity software powered by machine learning is rapidly becoming a requirement, rather than a luxury [7].

This paper describes the architecture of intelligent zero trust, which provides a framework for utilizing AI engines to deploy ZTA. The proposed AI-based policy engine is composed of three major components: 1) Static Policies, 2) Security Feeds, and 3) ML policies.

The remainder of the paper is structured as follows. Sections II and III delineate some background and related work, respectively. In section IV, the problem statement is provided. Section V presents the proposed approach to explore artificial intelligence for deploying ZTA. A set of performance results delineating the efficiency of the proposed approach is given in Section VI. Finally, Section VII includes closing remarks.

II. BACKGROUND AND RELATED WORK

A. Zero Trust Architecture (ZTA)

In the 1980s, US President Ronald Reagan used this phrase to describe the USSR: "Trust, but verify" [8], which backs recently with businesses are undergoing a digital transformation because of the proliferation of IoT technologies, multiple cloud platforms, and containers. As a result, companies increasingly rely on the use of identities and identifiers. Unsurprisingly, these identifiers are attractive targets for hackers. Corruption of credentials and identity theft are the main causes of security incidents and data breaches. In addition, the work environment is changing across the world. Trends telecommuting, fueled by the COVID-19 pandemic, is accelerating the adoption of cloud platforms and increasing the need to efficiently authenticate and grant access to corporate resources based on contextual, adaptive decisions, and dynamic, at the access point.

These developments have led the US NIST to standardize ZTA. Hence, NIST SP 800-207, Zero Trust Architecture, serves as a blueprint for the implementation of a zero-trust and "offers deployment models and use cases where the zero-trust strategy can improve an organization's overall security posture in security technology". The NIST defines the notion of zero-trust as "a collection of concepts and ideas designed to reduce uncertainty by implementing precise, on-demand, least privileged access decisions in specific settings". The notion of zero-trust extends beyond protecting the IT perimeter, a concept that has dominated traditional security, recognizing that when it comes to security, trust is a vulnerability. The fundamental zero trust concepts are presented in Fig. 1 and described in further detail below [4].

- **Zero Trust:** All network assets and functions, including devices, computing resources, and services, are regarded as untrustworthy regardless of their location on the network. As a result, all communications must comply with the same security requirements as contacts with third parties.
- **Trust/Risk Assessment:** Each access request is thoroughly vetted for trust and risk. Assessment that is continuous (for the duration of the access) and dynamic (based on situational conditions).
- **Least Privilege:** Access should be granted with the fewest available rights. Access is granted to a single resource (depending on the sensitivity of the resource) and is not transferable to another.
- **Dynamic Policy:** Access decision-making requires a dynamic policy. The essential decision factors include the subject's and network assets' security state, as well as the subject's and network assets' behavioral traits.

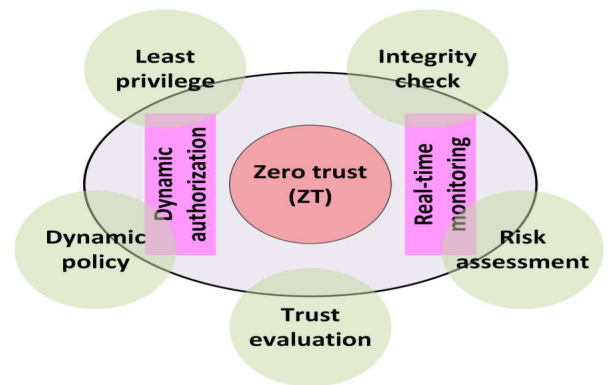


Figure 1. Key zero trust principles for information security [4]

- **Integrity Check:** The security state of all network assets and requestors is monitored continuously, ideally in real-time. An automated system assesses the security posture of devices and the user/network asset behavior against security policy standards.

The zero-trust model is proposed to overcome the current security problems by developing the concept of perimeter-less. The zero trust is above all an architectural concept dedicated to strengthening the security of access to resources and services and not a technology in itself, a fortiori it is not a commercial all-in-one software solution. In a traditional perimeter defense logic, users connected from the network of the entity have the right to access large resources, without the application of measures elementary partitioning or subsequent checks on their authentication and access to their session: users are assumed to be "trusted". The zero-trust approach consists, on the contrary, in reducing the "implicit trust" placed in users and activities carried out through the entity's equipment [9]. The "protections perimeter" does not disappear as there are always, for example, firewalls, proxies, trusted directories. However, in the ZTA, it is worth mentioning that access rules should be as granular as possible to set up the least privileged access required for taking the necessary action. To achieve this goal, the zero-trust strategy should be governed by dynamic policies, which are implemented at each session and updated based on the information collected on the current state of the customer's identity, application/service, and the asset responsible for the demand, including other environmental and behavioral attributes. Also, organizations that implement the zero-trust model should be able to monitor and assess the security and integrity posture of all owned and associated assets [10].

Accordingly, a complete switch to a zero-trust model seems unlikely for entities endowed with an inherited and sedimented IT heritage because it would require an overhaul of the total information system. The promoters of zero-trust logically defend a better progressive implementation. The proposed strategy makes use of the zero-trust model as a process in two stages, the first consisting of integrating into the "traditional" set of encryption, tools to prevent data loss (data loss prevention), conformity checks (NAC type). NIST anticipates a transformation incremental system: the entities will first operate a hybrid system implementing a halfway between the zero trust model and the perimeter model.

B. Artificial Intelligence in Cybersecurity

Artificial intelligence (AI) is already being used in a wide variety of applications to boost productivity, increase revenue, and improve customer experiences. However, one critical, though sometimes underestimated, use of AI is to increase cyber-attack security. When combined with traditional approaches, AI is an extremely effective tool for defending against cybersecurity assaults. With hackers' capacity to steal or do harm remotely in the Internet Age, protecting assets and operations from those seeking to harm has grown more challenging than ever. A single company, Cisco, said it blocked seven trillion attacks on behalf of its customers in 2018 [11].

In light of this, organizations have begun leveraging AI to assist them in managing an increasing spectrum of cybersecurity threats, technological obstacles, and resource restrictions by strengthening the robustness, resilience, and reaction of their systems [12]. According to estimates, the market for artificial intelligence in cybersecurity will increase from \$3.92 billion in 2017 to \$34.81 billion in 2025, expanding at a compound annual growth rate (CAGR) of 31.38 percent over the projected period [13]. Network security is the most commonly used application, followed by data security and endpoint security. Three broad areas may be found when it comes to the usage of AI in cybersecurity: detection (51%), prediction (34%), and reaction (34%). (18 percent). The following factors are accelerating the adoption of AI in cybersecurity [14], [15]:

1. Speed of impact: Today's kinds of attacks have a rapid impact, and there are few opportunities for human connection in the meantime.

2. Operational complexity: Given the spread of cloud computing platforms and their capacity to be operationalized and supply services very fast – in the millisecond range – it is unfeasible to have many humans in the loop.

3. Cybersecurity skills shortages: There is a global cybersecurity skills shortfall of around a million and a half. This level of scarcity forces the sector to accelerate the automation of operations.

AI may assist security teams in three ways: by increasing the robustness, responsiveness, and resilience of systems. This is referred to in the report as the 3R model [16]. To begin, AI may enhance a system's resilience, or its capacity to keep its original presumed stable configuration even when faced with erroneous inputs, through the use of self-testing and self-healing software. This indicates that AI systems may be utilized to enhance robustness testing by outsourcing verification and validation to machines. Second, AI may bolster a system's resilience, or its capacity to withstand and resist an assault, by simplifying threat and anomaly identification. Thirdly, AI may be used to improve system reaction, i.e. a system's ability to respond autonomously to assaults, to detect weaknesses in other machines, to operate strategically by determining which vulnerability to target and when to attack it, and to launch more aggressive counterattacks. In many circumstances, AI will complement, rather than replace, human security analysts' decision-making

and will be integrated into systems that expedite reaction activities.

Automation will pervade all facets of security operations, including zero trust. Recent growth in popularity of security orchestration, automation, and response (SOAR) technologies cleared the path for comparable automation in zero-trust implementations. SOAR already enables automated patching, system, software, and firmware upgrades, as well as automated reaction to known or aberrant behavior [17]. Zero trust architectures will extend this to automated user lifecycle management, in which user and non-human entity identities will be safely established, credentialed, de-credentialed, and removed without operator interaction. Automated monitoring, visibility, and real-time dashboards provide operators with a real-time view of the security infrastructure, its behavior, and trends, as well as the ability to spot potential threats. Eventually, automation will enable the development, modification, and destruction of whole security systems with a single click. By and large, AI has infiltrated every aspect of security, and zero trust solutions are the next frontier.

III. RELATED WORK

This section discusses several techniques and implementations for ZTAs currently available. To begin, we will examine the more theoretical methods and notions advanced in research publications. Following that, we highlight many significant enterprise-level ZTA installations [18].

A. ZTA Theoretical Approaches

DeCusatis et al. [19] recognized the limits of existing network segmentation best practices. They discussed a unique architecture as a facilitator of a zero-trust approach, based on a steganographic overlay. Technically speaking, the steganographic overlay conceals authentication tokens within the first packet of authentication and Transmission Control Protocol (TCP) requests. The experiment was deployed in both on-premises and cloud computing settings. Embrey [20] listed the top three reasons for ZTA adoption and emphasized the importance of enhancing security and policy controls at the user and device levels. Mehraj and Banday [21] suggested a conceptual zero-trust technique that was purpose-built for cloud computing settings. Additionally, their efforts emphasized the development of trust and the additional trust difficulties associated with cloud computing.

Yan and Wang [9] surveyed zero-trust components and major zero-trust technologies. Additionally, they implemented some of the topic technologies and tied them to real scenarios to emphasize the benefits of ZTA. Mital [22] explored the characteristics of Distributed Ledger Technology (DLT) and the blockchain technology that is relevant in a zero-trust environment. The author highlighted in detail how the immutability attribute of blockchain technology may aid in the establishment of greater integrity standards. Additionally, the absence of a hypothetical single point of failure in ZTA may aid in increasing the system's/availability, networks owing to the "inherent" relevant features of DLT.

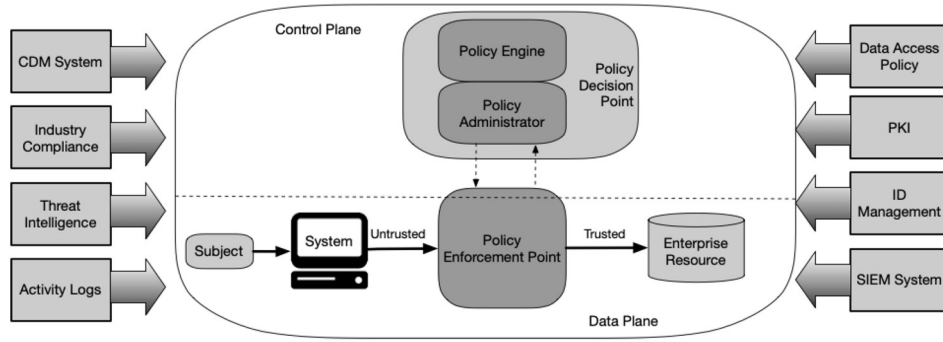


Figure 2. Core Zero Trust Logical Components [4]

B. Real-world ZTA Implementations

In this part, we examine 3 "real-world" ZTA approaches: VMware's NSX [23], Google's BeyondCorp [24], and Forrester's NGFW/ZTX [25].

i. Virtualization software VMware NSX

This paradigm is most applicable to organizations that currently use Virtual Desktop Infrastructure (VDI) [23]. Two critical components of the NSX-based method are the virtual server and the virtual desktop. In this situation, NSX functions as a firewall, performing and enforcing policy choices and trust management throughout the network as a whole and at numerous points. As a result, the administrative team may execute access control fine graining in a variety of segments, a process known as micro-segmentation.

ii. Google's BeyondCorp

Google initiated the BeyondCorp initiative in 2009 in response to a hacking attempt by the Anonymous organization dubbed Operation Aurora [24]. In general, the attackers gained access to the internal network by targeting intellectual property sources and using the compromised system as a jumping-off point (also known as a "jump-point") to move laterally. As a result, Google's primary goal was to weaken the implicit trust that its users and devices had formed as a result of their physical or electronic presence (or both) within the corporate network.

iii. Forrester (Extended Zero Trust) ZTX

When and when appropriate, a centralized segmentation engine controls and separates the enterprise network into several Micro Core and Perimeter (MCAP) segments. As such, it is capable of enforcing traffic laws in the intervals between MCAPs. This technique corresponds to NIST's "Resource Portal" paradigm. Because the needed changes to components before implementation are minimal or near nil, this paradigm may be an appealing solution. However, this paradigm enforces trust by utilizing the information included in data packets. This is a less "granular" approach than designs that deeply connect with endpoints and services. Additionally, this solution has the disadvantage of preventing users from being verified directly with the NGFW segmentation engine. More precisely, the segmentation engine is incapable of implementing regulations based on user and device contextual information.

IV. PROBLEM STATEMENT

Given the current challenges, it is difficult for organizations to configure and tune the security policies for blocking and allowing necessary access to their assets. The current limitations in security policies evoke the need to migrate from legacy layer 4 firewall security policies that only match sources, destinations, and protocols, which could be easily deceived by attackers. However, the effort and time consumed to maintain these policies is a critical issue faced by many organizations as currently they are required to manually configure firewall rules for each layer 4 traffic flow, which delays the entire process and business delivery. It cannot be neglected how this will exponentially grow while working with zero trust policies given the number of factors each zero-trust policy requires.

This will require security admins to not only ask the common three questions (Source, Destination, and application), but they will be asked to provide all the Kipling method questions (Who, What, When, Where, Why, and How). Following the same old process of manually configuring the policies will impose more delay on the overall process. As previously mentioned, most of the current security research uses artificial intelligence and machine learning to classify traffic (malicious or legitimate). Here, we will introduce a conceptual model that could be used to help security administrators better tune their policies and dedicate more time to doing what is important for their environment.

V. PROPOSED APPROACH

A. AI-based Zero Trust Policy Engine

According to the current core zero trust logical components that are mentioned by NIST (see Figure 2), we will discuss how the implementation of the Policy Engine (PE), which is responsible for the ultimate decision to grant access to a resource for a given subject. As well, we will discuss how the PE should be implemented to reduce the effort required to maintain a secure posture. As shown in Figure 3, we propose the PE to include three main components as follows:

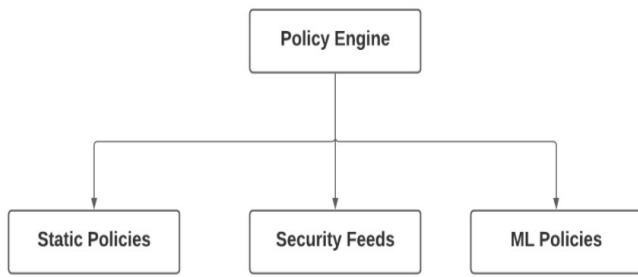


Figure 3. Main components of the proposed AI-based Zero Trust PE

(1) Static Policies: It's a well-known fact by now that zero trust policies contain more data and input than the normal legacy network policies. Static policies will be the most dominant component in the PE structure as it contains policies configured by security engineers. This is typically used to map a specific organization policy or as a first mitigation technique in the event of a zero-day attack. Policies will be configured directly and applied immediately, which would be beneficial, especially in the case of mitigation, (e.g., all access to a specific resource or IP must be denied) and will be crafted to follow the Kipling Method by answering the below questions:

- User-ID becomes a WHO statement: "Who is accessing a resource?" This could be a user, application, asset, or service and must be governed by Identity and Access Management IAM.
- App-ID becomes a WHAT statement: "What application is being used to access the resource?"
- Content-ID becomes a HOW statement: "How should the User-ID and App-ID traffic be allowed to access a resource?"
- WHEN statement (a time delineated rule).
- WHERE statement, which is the location of the resource.
- WHY using metadata from a data classification tool and using that in the rule.

The static rules engine provides a way to generalize the security rules configuration like the use of regex or grouping from any identity management like Active Directory. Here in our sample code, we will use local identities, but the same concept applies to any identity provider. In the proposed approach, the rules statically configured by security admins will be used to train the machine learning algorithm to validate data network flows in case they don't match any pre-configured security rule.

(2) Security feeds: To maintain the same security posture as older security controls, the PE should make use of the security feeds provided by different sources, e.g., well-known malicious domains and URLs, or IPs with a bad reputation; as well as the gathered information from different resources; system for continuous diagnostics and mitigation (CDM). This gathers information about the enterprise asset's current state. Threat intelligence feed(s) from external sources and provide information about newly discovered attacks or

vulnerabilities. SIEM solutions provide log analysis on logs from different sources and alerts based on configured use cases.

(3) Machine Learning Policies: Using the same features in the Kipling method (who, what, when, where, why, how), we could deal with the allow/block queries as a classification problem, so different machine learning techniques could solve them. Different techniques could be used to generate the training data that will be used (for example, the white team provides the allowed data set, and the red team (penetration test team) provides the block data set). In addition, we could use a trusted team member from each team to build the policy based on their behavior. After the flow is validated against the static policies and security feeds, it will be validated against the trained model to be classified.

B. Machine Learning Algorithm

Machine learning is a method of data analysis that automates analytical model building. For the machine learning algorithm to train their model, they require a minimum amount of training data, which differs based on the model used and the complexity of the model to be built. Given that the proposal at hand is new for solving the Zero Trust configuration issues, we selected the decision tree algorithm. This is justified because it is one of the most practical and widely used methods for inductive inference, which is generally used to approximate discrete-valued functions that are robust to noisy data and capable of learning disjunctive expressions [26], as it can work with a relatively small amount of data set and is easy to visualize to understand the behavior of the algorithm after training.

To enhance the training data, we will make use of regex for the static policies and then generate all the permutations that match the policies configured. Below is a sample of configured policies in Table 1. As shown, all the fields mentioned in the policies do not have numeric values, and to be used in machine learning, we have to make use of the One Hot Encoder. In addition to helping organization start in the zero-trust initial implementation, machine learning algorithm could be more tuned for better results by updating the manual security policies created by security admins which mean that not only admins will create dedicated policies in case of a specific flow needs to be allowed but also the algorithm will use it to train more and build a better model or what could be referred to as continuous learning.

C. Implementation Procedure

For demonstrating purposes, we implemented the described logic in Python for ease of use and its support for different machine learning algorithms. As well, we used python scikit-learn for machine learning algorithms implementation, which is a simple and efficient tool for data analytics. All the input data, including the static policies and the security feeds, is in Comma-Separated Values (CSV) format due to its wide usage in the machine learning community.

The developed code mainly consists of five different Python classes implemented separately to provide a high level of abstraction, easing enhancement of the implemented modules or adding more in future work.

- i. Data Cleaning: the first class will be used for input validation and to check the input policies of the users, resolve any regex mentioned, and ensure that all the data input is compliant with the required format.
- ii. Kipling Traffic Flow: this class will be used to map the Zero Trust traffic flow mapped to the Kipling method (Who, What, How, When, Where, and Why) to be used later with different components for validation.
- iii. Static Policy Agent: this class will be used to validate each Kipling traffic flow against the statically configured zero-trust policies, and its actions will be dominant over any other module.
- iv. Security Feeds: this class will be used to validate the traffic flow against any external security feeds. For simplicity, we used the input to be a CSV file; but this could be used to digest input from different resources like open-source security feeds from the community or different security vendors.
- v. Machine Learning: This class uses the statically configured policies as a training dataset for the machine learning algorithm to validate any traffic flow that does not match the static policies, or the destinations mentioned in security feeds. In our case, we are using the decision tree algorithm implemented by scikit-learn which could be easily replaced with any other algorithm in future work to get better results.

The below pseudocode [Algorithm 1] gives a high-level view of the logic used inside the algorithm, and the full code can be found in the code repository in [27].

Algorithm 1. Validate Traffic Flow

```

Data:   Kipling Traffic Flow
Result: Action allow or deny
begin:
    cleanedFlow = new();
    switch StaticPolicyAgent.validate(cleanedFlow) do
        case allow: return allow;
        case deny:  return deny;
        default:
            switch SecurityFeeds.validate(cleanedFlow) do
                case deny: return deny;
                default: return ML.validate(cleanedFlow);
            end switch
        end switch
    end

```

Table 1. Statically Configured Policies

UserID	destID	AppID	ContentID	When	Where	Action
HR	HRSer	HTTPS	Content	WH	*	allow
HR	HRSer	SSH	Content	WH	*	allow
HR	*	*	Content	NS	*	deny
HR	FinSer	*	*	*	*	deny
HR	RegSer	*	*	*	*	deny
Fin	FinSer	HTTPS	Content	WH	HQ	allow
Fin	FinSer	SSH	Content	WH	HQ	deny
Fin	FinSer	*	Content	WH	Remote	deny
Fin	*	*	Content	NS	*	deny
Fin	HRSer	*	*	*	*	deny
Fin	RegSer	*	*	*	*	deny
Fin	MedSer	*	*	*	*	deny
Reg	RegSer	HTTPS	Content	WH	*	allow
Reg	RegSer	SSH	Content	WH	*	allow
Reg	*	*	Content	NS	*	deny
Reg	FinSer	*	*	*	*	deny
Reg	HRSer	*	*	*	*	deny
Reg	MedSer	*	*	*	*	deny
Med	MedSer	HTTPS	Content	*	*	allow
Med	MedSer	SSH	Content	*	*	deny
Med	FinSer	*	*	*	*	deny
Med	RegSer	*	*	*	*	deny
Tech	*	SSH	Content	*	*	allow

D. Data Set

Firewall policy datasets are often hard to obtain because of privacy issues. Many entities are unwilling to share their network policies and logs. Network policies often contain private information. In particular, any misconfiguration identified could be used for malicious activities. Therefore, the data set was specially created for this work and was never used before trying to mimic the structure of a Small to Medium Enterprises (SMEs') general rules containing different departments and allowing access based on each department profile. It consists of 133 policies as training data and 20 policies to be used for testing, which are summarized in Table 1.

VI. RESULTS

This approach was designed to test the hypothesis that zero-trust network policies could be predicted from the policies configured by administrators. In addition, we were interested in answering the following questions: 1) Could machine learning help to optimize in policies configuration? and 2) How accurate will machine learning decisions be given the lack of data?

Figures 4 and 5 show the result from the classification tree algorithm applied on the sample data mentioned in Table 1, where class 0 and 1 represent the resulting actions "allow" and "deny", respectively. This small dataset was only presented to show how the "Decision Tree Algorithm" could help visualize the decision-making. Definitely, trying more sophisticated machine learning algorithms will require a more reliable data set. The initial resultant accuracy for the testing set was 75%. After applying different trials on the randomization state of the tree, we were able to reach 85 %.

Table 2 shows different performance measures for the used algorithm based on precision and recall. It seems that the decision is biased toward allowing the traffic, which is counterintuitive as in the security domain, denying is always the default action to be applied. This could be traced back to the quality of the statically configured policies, which will be enhanced in a real-world scenario by the security administrators.

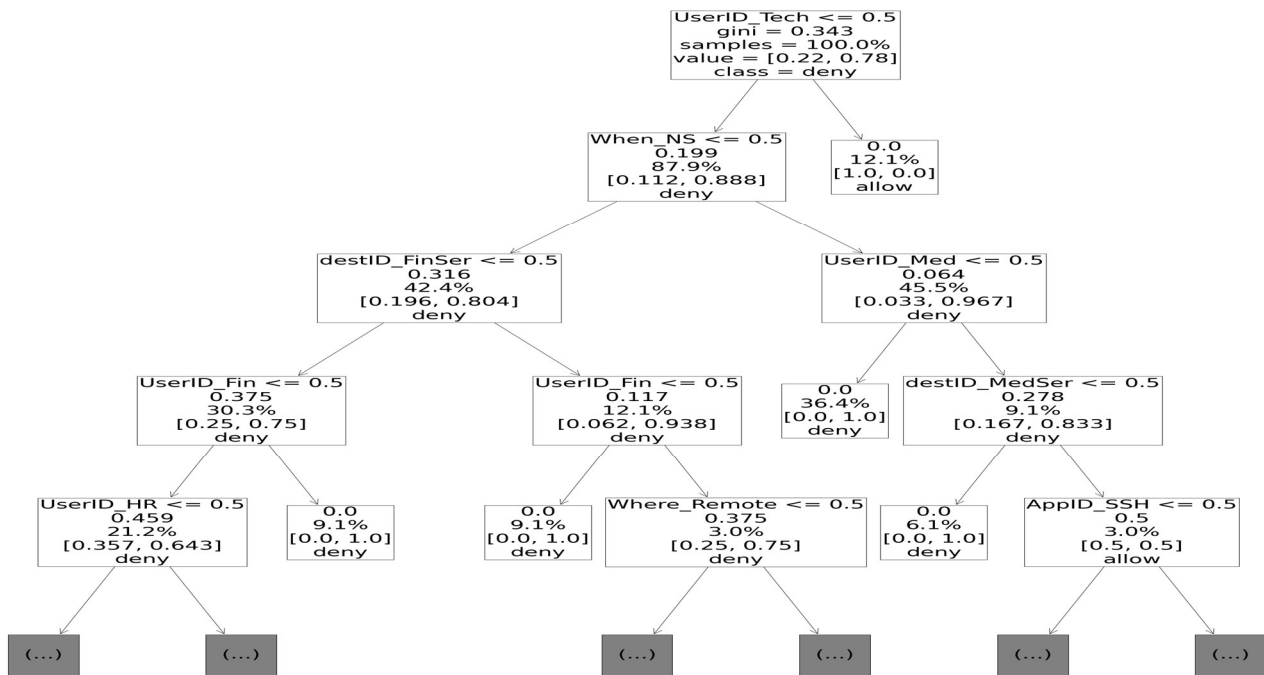


Figure 4. Visual Representation of the resulting Decision Tree

```

--- UserID_Tech <= 0.50
--- When_NS <= 0.50
--- destinationID_FinSer <= 0.50
--- UserID_Fin <= 0.50
--- UserID_HR <= 0.50
--- destinationID_RegSer <= 0.50
--- UserID_Reg <= 0.50
--- AppID_SSH <= 0.50
--- class: 0
--- AppID_SSH > 0.50
--- class: 1
--- UserID_Reg > 0.50
--- class: 1
--- destinationID_RegSer > 0.50
--- UserID_Med <= 0.50
--- class: 0
--- UserID_Med > 0.50
--- class: 1
--- UserID_HR > 0.50
--- destinationID_RegSer <= 0.50
--- class: 0
--- destinationID_RegSer > 0.50
--- class: 1
--- UserID_Fin > 0.50
--- class: 1
--- destinationID_FinSer > 0.50
--- UserID_Fin <= 0.50
--- class: 1
--- UserID_Fin > 0.50
--- Where_Remote <= 0.50
--- AppID_HTTPS <= 0.50
--- class: 1
--- AppID_HTTPS > 0.50
--- class: 0
--- Where_Remote > 0.50
--- class: 1
--- When_NS > 0.50
--- UserID_Med <= 0.50
--- class: 1
--- UserID_Med > 0.50
--- destinationID_MedSer <= 0.50
--- class: 1
--- destinationID_MedSer > 0.50
--- AppID_SSH <= 0.50
--- class: 0
--- AppID_SSH > 0.50
--- class: 1
--- UserID_Tech > 0.50
--- class: 0

```

Figure 5. Text Representation of the resulting Decision Tree

Table 2. Performance measures

	Precision	Recall	F1-score
0 (Allow)	0.73	1	0.84
1 (Deny)	1	0.75	0.86
Accuracy			0.85

VII. CONCLUSION AND FUTURE WORK

Based on the results, we provided evidence on how classification machine learning algorithms could help in optimizing the implementation of ZT policies across a complex environment. As well, it shows how machine learning could be used to utilize the manual effort of admins not only to allow the traffic but also to enhance the model for better decision-making in upcoming requests. The preliminary results show that the proposed approach demonstrates the potential to identify the required policies to be configured and compare them against the traditional compliance rules to auto-configure the policies. However, due to the lack of a more robust data set, it is not clear to what extent this approach could be generalized.

Some ways that could be recommended to enhance this work are to find a reliable data set that contains the zero trust features as mentioned above to better train the model and to run more intensive testing. Another approach is to test various machine learning algorithms to find the most suitable one to be used in a live environment. Also, we can see that some of the features could be tuned instead of inserting them directly into the model. For example, we could use some sort of Natural Language Processing (NLP) techniques against the Why, also referred to as metadata, to provide initial classification or clustering techniques that would hopefully give more insights into the model instead of using the raw metadata.

References

- [1] M. J. Sousa and Á. Rocha, "Digital learning: Developing skills for digital transformation of organizations," *Future Generation Computer Systems*, vol. 91, 2019, doi: 10.1016/j.future.2018.08.048.

- [2] Cisco Systems Inc., "Cisco Annual Internet Report (2018–2023)," *Whitepaper, Cisco public*, 2020.
- [3] C. Buck, C. Olenberger, A. Schweizer, F. Völter, and T. Eymann, "Never trust, always verify: A multivocal literature review on current knowledge and research gaps of zero-trust," *Computers and Security*, vol. 110, 2021, doi: 10.1016/j.cose.2021.102436.
- [4] NIST, "Zero Trust Architecture, SP 800-207," *National Institute of Standards and Technology Special Publication*, vol. SP 800-207, 2020.
- [5] I. Wiafe, F. N. Koranteng, E. N. Obeng, N. Assyne, A. Wiafe, and S. R. Gulliver, "Artificial Intelligence for Cybersecurity: A Systematic Mapping of Literature," *IEEE Access*, vol. 8, 2020, doi: 10.1109/ACCESS.2020.3013145.
- [6] Q. Liu, P. Li, W. Zhao, W. Cai, S. Yu, and V. C. M. Leung, "A survey on security threats and defensive techniques of machine learning: A data driven view," *IEEE Access*, vol. 6, 2018, doi: 10.1109/ACCESS.2018.2805680.
- [7] Y. Xin *et al.*, "Machine Learning and Deep Learning Methods for Cybersecurity," *IEEE Access*, vol. 6, 2018, doi: 10.1109/ACCESS.2018.2836950.
- [8] N. Daniloff, "Suzanne Massie, Trust but Verify: Reagan, Russia, and Me . Rockland, ME: Maine Authors Publishing, 2013. 380 pp.," *Journal of Cold War Studies*, vol. 18, no. 4, 2016, doi: 10.1162/jcws_r_00693.
- [9] X. Yan and H. Wang, "Survey on Zero-Trust Network Security," in *Communications in Computer and Information Science*, 2020, vol. 1252 CCIS. doi: 10.1007/978-981-15-8083-3_5.
- [10] L. Ferretti, F. Magnanini, M. Andreolini, and M. Colajanni, "Survivable zero trust for cloud computing environments," *Computers and Security*, vol. 110, 2021, doi: 10.1016/j.cose.2021.102419.
- [11] U. Noor, Z. Anwar, T. Amjad, and K. K. R. Choo, "A machine learning-based FinTech cyber threat attribution framework using high-level indicators of compromise," *Future Generation Computer Systems*, vol. 96, 2019, doi: 10.1016/j.future.2019.02.013.
- [12] F. Musumeci, A. C. Fidanci, F. Paolucci, F. Cugini, and M. Tornatore, "Machine-Learning-Enabled DDoS Attacks Detection in P4 Programmable Networks," *Journal of Network and Systems Management*, vol. 30, no. 1, 2022, doi: 10.1007/s10922-021-09633-5.
- [13] J. hua Li, "Cyber security meets artificial intelligence: a survey," *Frontiers of Information Technology and Electronic Engineering*, vol. 19, no. 12, 2018, doi: 10.1631/FITEE.1800573.
- [14] C. Benzaid and T. Taleb, "AI-Driven Zero Touch Network and Service Management in 5G and Beyond: Challenges and Research Directions," *IEEE Network*, vol. 34, no. 2, 2020, doi: 10.1109/MNET.001.1900252.
- [15] Frost & Sullivan, "The 2017 Global Information Security Workforce Study: Benchmarking Workforce Capacity and Response to Cyber Risk," 2017.
- [16] M. Taddeo, T. McCutcheon, and L. Floridi, "Trusting artificial intelligence in cybersecurity is a double-edged sword," *Nature Machine Intelligence*, vol. 1, no. 12, 2019, doi: 10.1038/s42256-019-0109-1.
- [17] J. Kinyua and L. Awuah, "Ai/ml in security orchestration, automation and response: Future research directions," *Intelligent Automation and Soft Computing*, vol. 28, no. 2, 2021, doi: 10.32604/iasc.2021.016240.
- [18] L. Alevizos, V. T. Ta, and M. Hashem Eiza, "Augmenting zero trust architecture to endpoints using blockchain: A state-of-the-art review ," *SECURITY AND PRIVACY*, vol. 5, no. 1, 2022, doi: 10.1002/spy2.191.
- [19] C. Decusatis, P. Liengtiraphan, A. Sager, and M. Pinelli, "Implementing Zero Trust Cloud Networks with Transport Access Control and First Packet Authentication," 2016. doi: 10.1109/SmartCloud.2016.22.
- [20] B. Embrey, "The top three factors driving zero trust adoption," *Computer Fraud and Security*, vol. 2020, no. 9, 2020, doi: 10.1016/S1361-3723(20)30097-X.
- [21] S. Mehraj and M. T. Banday, "Establishing a zero trust strategy in cloud computing environment," 2020. doi: 10.1109/ICCCI48352.2020.9104214.
- [22] R. Mita, "IMPROVING TRUST IN A ZERO TRUST ARCHITECTURE (ZTA)," *Getting it right - Collaborating for mission success*, vol. 10, no. 4, p. 2, 2020.
- [23] S. Keeriyattil, "Microsegmentation and Zero Trust: Introduction," in *Zero Trust Networks with VMware NSX*, 2019. doi: 10.1007/978-1-4842-5431-8_2.
- [24] R. Ward and B. Beyer, "Beyondcorp: a new approach to enterprise security," *login:: the magazine of USENIX & SAGE*, vol. 39, no. 6, 2014.
- [25] C. Cunningham, "The Zero Trust eXtended (ZTX) ecosystem," *Forrester, Cambridge, MA*, 2018.
- [26] R. Hierons, "Machine learning. Tom M. Mitchell. Published by McGraw-Hill, Maidenhead, U.K., International Student Edition, 1997. ISBN: 0-07-115467-1, 414 pages. Price: U.K. £22.99, soft cover.," *Software Testing, Verification and Reliability*, vol. 9, no. 3, 1999, doi: 10.1002/(sici)1099-1689(199909)9:3<191::aid-stvr184>3.0.co;2-e.
- [27] "ZTN-Policy-ML-Decision-Tree," 2022.